

Capítulo 16

Ataques a Servidores WEB

16.1. Objetivos

- Aprender como encontrar vulnerabilidades em servidores web
- Conhecer diferentes as diferenças entre Apache e IIS
- Descobrir como explorar as vulnerabilidades encontradas

16.2. Tipos de ataques

Servidores WEB normalmente são os primeiros alvos de atacante que queira entrar numa rede que tenha uma DMZ com servidores públicos sendo executados, sejam servidores de WEB, E-mail, FTP, Banco de Dados e etc.

A partir do comprometimento de um servidor na DMZ, fica muito mais fácil comprometer uma máquina da interna e conseguir acesso às informações confidenciais, ou comprometer a rede inteira.

Podemos dividir em dois grandes grupos os tipos de ataques mais lançados contra servidores WEB:

16.2.1. DoS

- Jamming Networks
- Flooding Service Ports
- Misconfiguring Routers
- Flooding Mail Servers

16.2.2. DDoS

- FTP Bounce Attacks
- Port Scanning Attack
- Ping Flooding Attack
- Smurf Attack
- SYN Flooding Attack
- IP Fragmentation/Overlapping Fragment Attack

- IP Sequence Prediction Attack
- DNS Cache Poisoning
- SNMP Attack
- Send Mail Attack

O grande risco de servidores WEB, é que os mesmo estão 24 horas no ar, 7 dias por semana. Havendo qualquer vulnerabilidade ou erro na configuração não há dúvida de que em um determinado momento será explorado, basta contar quantas horas isso vai demorar.

Além da exploração, para conseguir acesso ao servidor e seus arquivos, temos os ataques do tipo DoS e DDoS, que causam a indisponibilidade do serviço sendo executado, não permitindo acesso aos site hospedados no servidor WEB comprometido. Imagine as implicações e prejuízos de um ataque desse tipo num servidor que hospeda um site ou serviço importante, como uma loja online, por exemplo?

16.3. Fingerprint em Web Server

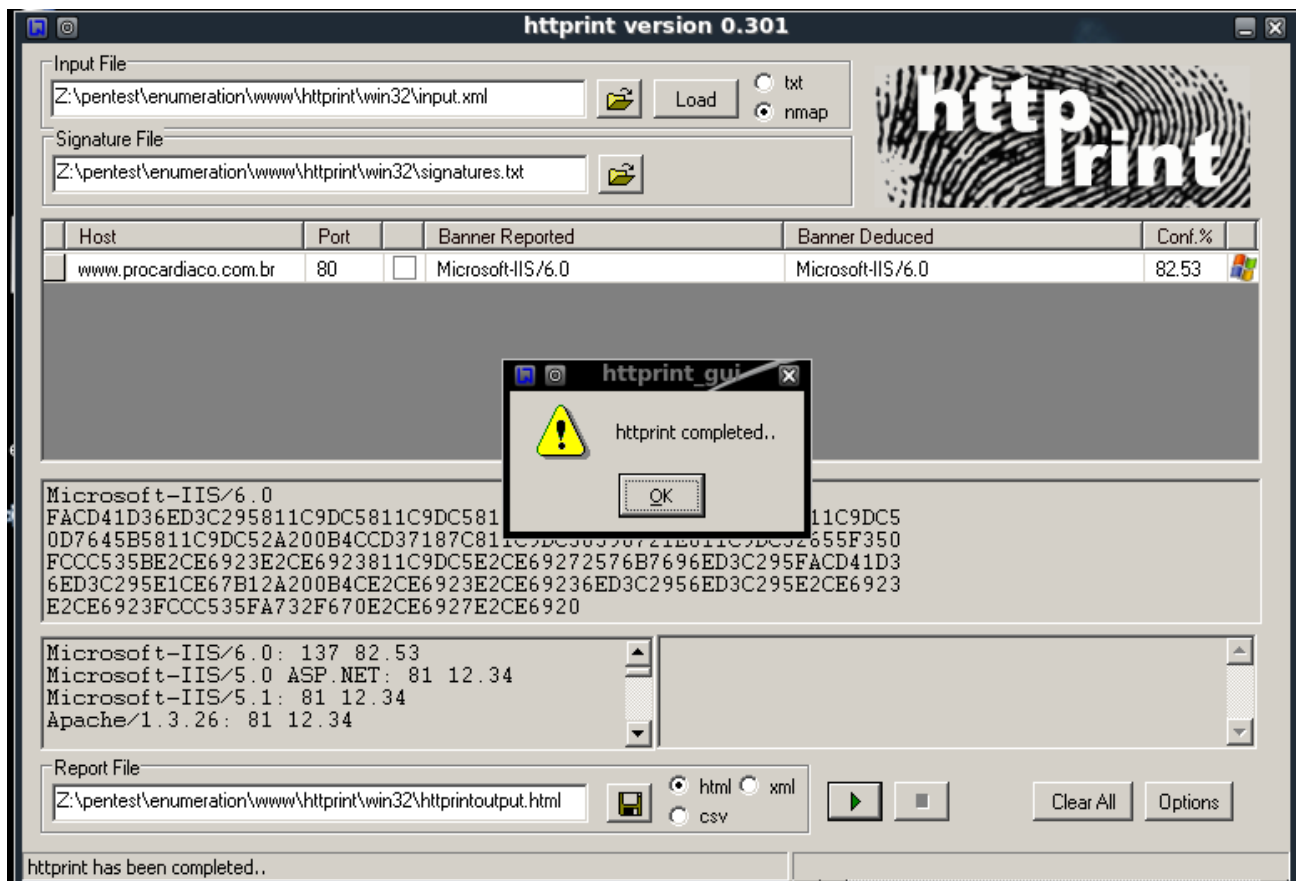
Antes de testar qualquer tipo de ataque contra um servidor WEB que tenha sido descoberto ao longo do processo de teste de invasão, precisamos ter acesso à algumas informações básicas sobre nosso alvo.

Um dos meios de se conseguir isso é através do fingerprint realizado sobre o servidor WEB, ou simplesmente usando o domínio hospedado no mesmo como parâmetro.

A seguir, vamos ver uma ferramenta que realiza esse procedimento automaticamente, bastando que informemos o nome do domínio hospedado.

16.3.1. Httpprint

Ferramenta para pegar o banner de identificação do servidor web.



A partir da imagem acima, usando um site qualquer como exemplo, descobrimos que, com 82.53% de certeza, o servidor sendo executado é o Microsoft-IIS/6.0, e o site foi construindo usando ASP ou ASP .NET. As demais possibilidades de servidor sendo executados, são mostrados na parte inferior esquerda da tela:

- Microsoft-IIS/5.0, com 12.34%
- Microsoft-IIS/5.1, com 12,34%
- Apache/1.3.26, com 12,34%

16.4. Descobrindo Vulnerabilidades com Nikto

Nikto é um script Perl usado para testar a segurança de seu servidor web. Ele faz a varredura em servidores Apache tanto em busca de vulnerabilidades, quanto de falhas de configuração, que podem, de alguma forma, expor o servidor à exploração por algum atacante malicioso, já que, se o servidor estiver hospedando algum site ou aplicação de acesso público, o risco de exploração é imenso.

Para atualizar e executar o Nikto, utilizamos os seguintes comandos:



```
# ./nikto.pl -update  
# ./nikto.pl -h 192.168.131.1 -o /192.168.131.1.txt
```

Podemos adicionar o sinalizador de evasão, que tenta contornar seus sistemas de IDS:



```
# perl nikto.pl -h www.xyz.com.br -evasion 1
```

Existem 9 opções diferentes para flags de evasão, 1 é para Random URL encoding (non-UTF8).

O processo fácil e descomplicado de instalação de uma plataforma LAMP (Linux, Apache, MySQL, PHP) permite a 'banalização' de servidores web na internet, configurados com vistas apenas a funcionalidade, sem considerar questões relativas à segurança.

A insegurança do servidor web não depende exclusivamente de falhas de configuração ou vulnerabilidades de software, muitas vezes os próprios usuários (webmasters) comprometem a segurança dos serviço.

Quem é da área com certeza já deparou-se com arquivos do tipo site.zip, senhas.txt, largados



no public_html. Muitos acham que pelo fato do diretório possuir -Indexes (desativar listagem de arquivos) o arquivo está seguro, é BESTEIRA pensar assim, ainda mais se o arquivo possui nome bem conhecido, webservers scanner adoram procurar esses arquivos.

O nikto permite a realização de diversos testes, vale uma olhada no diretório docs/ e uma lida no help:



```
# ./nikto.pl -Help | less
```

16.5. Auditoria e Exploração de Web Servers com W3AF



Essa ferramenta é um framework para auditoria e ataque em aplicações web.



Página do projeto: <http://sourceforge.net/projects/w3af/>

Vídeos: <http://w3af.sourceforge.net/videos/video-demos.php>

O mais interessante, é que podemos personalizar os testes que essa ferramenta pode realizar, podendo utilizar, também, profiles previamente configurados por padrão. Temos, por exemplo, o profile baseado na TOP10 OWASP, um relatório anual das vulnerabilidades mais exploradas, lançado pelo Projeto OWASP.

Outras possibilidades incluem varredura de auditoria, em busca de falhas de configuração ou sitemap, que nos retorna um mapa completa do site analisado.

16.6. Online Scanner

Há várias ferramentas online que podemos utilizar para fazer a varredura de web servers e obter informações necessárias para a exploração de vulnerabilidades encontradas.



<http://www.netcraft.com/>

<http://www.zerodayscan.com/>

O site Netcraft oferece informações sobre as configurações do servidor onde o site está hospedado, sobre domínios vinculados ao que está sendo pesquisado e muitas outras informações importantes para podermos realizar um ataque com sucesso.

Search Web by Domain

Explore 1,382,566 web sites visited by users of the [Netcraft Toolbar](#)

29th June 2010

Search: [search tips](#)

example: site contains .netcraft.com

Results for 4linux.com.br

Found 3 sites

	Site	Site Report	First seen	Netblock	OS
1.	www.4linux.com.br		march 2002	sago networks	linux
2.	netclass.4linux.com.br		august 2005	sago networks	linux
3.	webclass.4linux.com.br		july 2009	sago networks	linux

COPYRIGHT © NETCRAFT LTD 2010. ALL RIGHTS RESERVED.

Já o ZeroDayScan, é um site que permite fazer a varredura em busca de vulnerabilidades que possam existir em sua aplicação. O que é mais interessante, é que quando realizamos a busca, ele também retorna no relatório final, o endereço de todos os outros domínios hospedados no mesmo servidor.

Quando um atacante busca acesso à um servidor WEB, basta descobrir vulnerabilidades em qualquer um dos sites hospedados no mesmo e explorá-las para obter sucesso em seu ataque.

O único empecilho para realizar um ataque desse tipo, é que é necessário hospedar um arquivo txt como nome de “zerodayscan.txt”, como comentado no capítulo sobre vulnerabilidades em aplicações WEB.

16.7. Contramedidas

- Realizar constantes verificações nas configurações de segurança dos servidores web.
- Atualizar constantemente os servidores.
- Diminuir ao máximo as informações que são transmitidas pelos web servers às ferramentas de fingerprinting.

Capítulo 17

Ataques a Redes Sem Fio

17.1. Objetivos

- Entender as técnicas para acessar as redes sem fio
- Uma visão sobre WEP, WPA e as técnicas de ataque
- Entender como funciona o ataque baseado em Rainbow Tables

17.2. Introdução

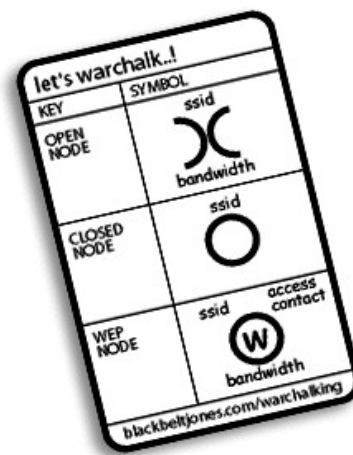
Nunca deixe sua rede wireless desprotegida, sem senha ou com protocolo WEP, pois por padrão será quebrado por qualquer pessoa com pouco conhecimento, podendo assim ter acesso a informações confidenciais.



Uma rede wireless mal projetada pode driblar todo o arsenal de defesa já implementado. Vamos imaginar a seguinte situação: sua empresa colocou uma muralha (ex: firewall) para proteção dos ataques. Porém, a muralha é completamente ineficiente contra os ataques aéreos (ex: wireless). Antes de começar a implementar uma rede wireless, faça um planejamento e estude toda a topologia da rede. Não se esqueça de evitar os ataques aéreos!

17.3. Wardriving

Um dos ataques mais comuns e comentados em redes wireless é o War Driving, que tem como objetivo “andar” com um dispositivo wireless em busca de Access Points. Esse ataque tira proveito de uma característica fundamental: é difícil controlar e limitar o alcance de redes wireless. O atacante pode estar neste exato momento “passeando” no seu carro e com o laptop ligado “procurando” redes wireless vulneráveis.



Essa técnica tem como objetivo identificar as redes sem fio acessíveis de um determinado local.

17.4. Ataques ao protocolo WEP

As informações que trafegam em uma rede wireless podem ser criptografadas. O protocolo WEP (Wired Equivalent Privacy) aplica criptografia avançada ao sinal e verifica os dados com uma “chave de segurança” eletrônica. Porém, a Universidade de Berkeley revelou a possibilidade de alguns tipos de ataques que exploram falhas no algoritmo WEP. Baseados em análises que exploram fraquezas do algoritmo RC4, uma senha WEP pode ser descoberta. Humphrey Cheung escreveu o artigo *How To Crack WEP*, descrevendo passo a passo como descobrir a senha do protocolo WEP.

O artigo pode ser obtido na url <http://www.isaac.cs.berkeley.edu/isaac/wep-faq.html>.

Após a publicação do artigo, surgiram algumas ferramentas que exploravam o problema descrito no mesmo. Um exemplo de ferramenta é o aircrack.

O aircrack é um conjunto de ferramenta bastante poderoso e amplamente usado para realizar ataques a redes sem fio.

Vamos ver um passo a passo de uso do programa para descobrir uma chave wep.

Em primeiro lugar, vamos fazer uma varredura para ver as redes WiFi existentes no ambiente:



```
# iwlist scan
```

Colocando a interface wireless em modo monitor:



```
# airmon-ng start wlan0
```

Iniciando a captura dos pacotes:



```
# airodump-ng --ivs -w wep -c canal_da_rede mon0
```

Onde:

-c = Canal

-w = Prefixo do arquivo a ser salvo

-i = Capturar apenas pacotes que contem IVs

wlan0 = Interface wireless

Agora, vamos enviar um pedido de falsa associação para o nosso alvo (Access Point), falando para ele aceitar os nossos pacotes:



```
# aireplay-ng -1 0 -e invasao_ap -a 00:00:00:00:00:01 -h 00:00:00:00:00:02 wlan0
```

Onde:

-1 = Opção para mandar uma autenticação falsa

0 = Tempo para reassociação, em segundos

-e = ESSID do alvo (Nome do access point)

-a = Mac Address do Access Point

-h = Nosso MAC Address

wlan0 = Nossa interface wireless

Agora, vamos tentar enviar arp request para a rede, na tentativa que alguma maquina receba e comece a enviar arp replay para nós, aumentando o tráfego rapidamente. Isso pode ser observado na tela do airodump-ng, onde a quantidade de "DATA" capturada aumentará rapidamente.



```
# aireplay-ng -3 -b 00:00:00:00:00:01 -h 00:00:00:00:00:02 wlan0
```

Onde:

-3 = Opção para arp request

-b = MAC Address do Access Point

-h = MAC Address usado na associação. Nesse caso, o nosso MAC

wlan0 = Nossa interface wireless

Agora que temos uma quantidade grande de pacotes, podemos executar o

aircrack para de fato, descobrirmos a chave:



```
#aircrack-ng -a 1 wep-01.ivs
```

Onde:

-a = Modo para forçar um determinado tipo de ataque

1 = WEP

wep-01.ivs = Arquivo gerado pelo airodump-ng (selecionamos o prefixo wep e apenas pacotes IVs)

Agora é aguardar que o aircrack-ng nos mostrará a chave. Caso ele não consiga, tente capturar mais pacotes e execute novamente.

17.5. SSID Oculto

Os SSID ocultos podem ser facilmente detectados através de sniffers, uma vez que o seu nome é trafegado sem criptografia em uma rede. Por isso, ocultar um SSID não aumenta a segurança de uma rede sem fio.

O próprio aircrack, utilizando o airodump, já nos mostra todos os SSID, incluindo os ocultos.

Caso um SSID não seja exibido, podemos utilizar a técnica de solicitação de deautenticação que realizaremos no ataque contra WPA para forçar um usuário a se conectar novamente, e com isso, capturamos o SSID que ele enviou durante o pedido de conexão.

17.6. MAC Spoofing

Algumas pessoas acreditam que estão seguras após liberar o acesso aos seus Access Points apenas para determinados MAC Address. O MAC address, que é um valor que vem de fábrica nas nossas interfaces de redes, pode ser alterado.

É relativamente simples “forjar” o endereço físico da sua placa de rede. Portanto, não podemos confiar apenas nesse controle para garantir a segurança de

uma rede sem fio.

Exemplo de comando no Linux para alterar o MAC Address:



```
# ifconfig wlan0 down hw ether 00:00:00:00:01:01
```

E como podemos conhecer o MAC Address de um usuário de uma determinada rede? Simples, sniffer novamente.

Como exemplo, podemos utilizar o airodump, e ele nos mostrará os clientes associados a um determinado Access Point. Com isso, basta utilizarmos o MAC Address desse cliente na nossa interface de rede que conseguiremos acessar o Access Point.

17.7. WPA Brute Force

Redes com WPA ainda não possuem uma vulnerabilidade como o WEP, onde conseguimos descobrir a chave após analisar o tráfego depois de um certo período de tempo. Porém, é possível realizar brute force contra o hash da senha enviada durante a conexão entre um cliente válido da rede e tentar descobrir a senha utilizada para conexão à rede.

Vamos exemplificar o ataque usando o conjunto de ferramentas do aircrack. Após colocar a placa novamente em modo monitor, como o exemplo acima, podemos executar o airodump-ng:



```
# airodump-ng -c 11 -w wpa mon0
```

Onde:

-c = canal

-w = prefixo usado no nome do arquivo que salvara os pacotes

Realizando a deautenticação de um cliente conectado ao alvo, pois queremos pegar a senha quando ele se reconectar:



```
# aireplay-ng -0 5 -a 00:00:00:00:00:01 -c 00:00:00:00:00:02 wlan0
```

Onde:

-o 5 = opção de deautenticação, enviando 5 requisições

-a MAC Address do Access Point alvo

-c MAC Address do cliente que vamos deautenticar

wlan0 = nossa interface wireless

Quebrando a senha capturada com o airodump-ng:



```
# aircrack-ng -a 2 -w wordlist.txt wpa-01.cap
```

Onde:

-a = Modo para forçar um determinado tipo de ataque

2 = WPA/WPA2-PSK

-w wordlist

wpa-01.cap = arquivo gerado pelo airodump-ng

17.8. WPA Rainbow Tables

Como já visto anteriormente, sabemos que a quebra de senhas com rainbow tables é muito mais rápida do que com wordlist.

Como o algoritmo de encriptação do protocolo WPA é mais forte do que WEP, é necessário utilizarmos rainbow tables para quebrar suas senhas.

Programa para usar rainbow tables:



```
./cowpatty -r [dump] -d [rainbow_table] -s [SSID]
```



<http://www.securitytube.net/Using-CowPatty-in-Backtrack-4-video.aspx>

Download de rainbow tables:



<http://www.security-database.com/toolswatch/WPA-Rainbow-Tables-Offensive.html>

17.9. Rouge Access Point

Rogue Access point são WLAN Access Points que não estão autorizados a conectar em uma rede. Um Rouge AP abre um “buraco” wireless na rede. Um hacker pode implantar um rogue Access point ou um funcionário pode criar um problema de segurança sem saber, simplesmente conectando um Access Point desconfigurado na rede da empresa.

Uma vez que foi identificado um novo AP na rede, sem configuração, basta que configuremos a nossa interface de rede para se conectar nesse novo ambiente desprotegido.



[http://www.securitytube.net/Attacks-on-WiFi-\(Rogue-Access-Point\)-video.aspx](http://www.securitytube.net/Attacks-on-WiFi-(Rogue-Access-Point)-video.aspx)

17.10. Wifi Phishing

WiFi phishing ocorre em hotspots públicos onde usuários utilizam access points.

O atacante aproveita-se do fato de que os SSID estão visíveis a todos na área coberta pela rede.



O atacante utiliza-se dessa informação e configura um access point com o mesmo SSID para convencer os usuários a se conectarem no access point falso.

Um método mais sofisticado ainda é forçar os usuários a se desconectar do

access point real e então conectar ao access point do atacante.

Ferramenta para configurar um access point:



```
# ./airsnarf
```

17.11. Contramedidas

- Utilizar senhas fortes nos Access point
- Não usar WEP
- Não confiar em controle de acesso via MAC Address
- Possuir uma política de segurança atualizada, que controle as redes sem fio.